

NIST CSF Current Profile

NIST CSF Target profile

Function	Current State	Evidence / Reference	Key Strength	Key Gap / Observation	Assessment Status		Function	Target State	Target Evidence / Measure	Target Objective	Priority	Timeframe	Status
GOVERN	Policy, RACI, and Management Review formally established; vendor security addenda in place for all critical vendors	Policies; RACI Matrix; Management Review Records; Vendor Security Addenda	Formal governance structure and vendor oversight established	No significant gap identified	Established		GOVERN	Vendor security risk tiered by criticality; supply chain risk formally reported at every Management Review	Vendor risk tiers; supplier risk reports; Management Review minutes	Strengthen third-party and supply chain risk governance	High	12 Months	Target
IDENTIFY	Asset and risk registers complete and reviewed annually; 15 risks assessed (R-001 to R-015)	Asset Register; Risk Register R-001 to R-015	Asset and risk identification processes established	Annual review cadence may require event-driven updates	Established		IDENTIFY	Near-continuous asset discovery, including shadow cloud resources, supplementing the annual manual review	Automated asset discovery reports; cloud inventory; discovery logs	Improve visibility of organizational assets and unmanaged resources	High	12 Months	Target
PROTECT	MFA at 100%, EDR deployed fleet-wide, awareness training at 89% and improving, encryption enabled on customer data at rest	MFA Evidence; EDR Deployment Records; Training Records; Encryption Configuration	Strong preventive security controls implemented	Awareness training remains below 100%	Mostly Established		PROTECT	95%+ sustained awareness completion; automated configuration drift scanning live across all cloud environments	Training completion reports; configuration drift reports; cloud security monitoring	Increase workforce security awareness and reduce cloud configuration risk	High	12 Months	Target
DETECT	SIEM deployed with daily alert triage; coverage gap remains on the legacy ERP system; no mean-time-to-detect metric currently tracked	SIEM Records; Alert Triage Logs; Monitoring Evidence	Continuous SIEM monitoring and daily alert triage established	Legacy ERP monitoring gap; MTTD metric not currently tracked	Partially Established		DETECT	Full monitoring coverage across all critical assets including legacy systems; mean-time-to-detect tracked and reported monthly	SIEM coverage reports; monitoring dashboards; monthly MTTD reports	Eliminate critical monitoring gaps and establish measurable detection performance	Critical	12 Months	Target
RESPOND	Incident response plan documented with a defined escalation path; has never been exercised via tabletop simulation	Incident Response Plan; Escalation Matrix	Formal incident response process documented	No tabletop exercise performed to validate response capability	Partially Established		RESPOND	Annual incident response tabletop exercise completed; communication plan validated against a simulated scenario	Tabletop exercise report; lessons learned; communication validation records	Validate incident response and communication effectiveness	High	12 Months	Target
RECOVER	Backup restoration tested quarterly with documented RTO/RPO; recovery communication plan remains untested	Backup Restoration Test; RTO/RPO Results; Recovery Plan	Regular restoration testing and documented recovery objectives	Recovery communication plan has not been tested	Partially Established		RECOVER	Recovery communication plan tested alongside each restoration test; lessons learned formally logged every cycle	Recovery test reports; communication test records; lessons-learned register	Improve recovery coordination and continuous improvement	Medium	12 Months	Target